

MFA ist nicht gleich MFA.

5 Massnahmen gegen Phishing und MFA-Fatigue

Warum klassische MFA fällt

MFA-Fatigue

Push-Anfragen im Minutentakt, bis jemand entnervt «Genehmigen» tippt.

Echtzeit-Phishing

Die gefälschte Login-Seite reicht Passwort und Code direkt an die echte weiter.

1

Number Matching aktivieren

Blindes Bestätigen fällt weg: Wer sich anmeldet, muss die angezeigte Zahl eintippen.

Microsoft Authenticator

2

Passkeys / FIDO2 einführen

Der Schlüssel funktioniert nur auf der echten Domain.
Fälschungen laufen ins Leere. Start: Admin-Konten.

FIDO2 · Passkeys

3

Legacy-Protokolle abschalten

Alte Protokolle umgehen MFA komplett. Vorher in den Logs prüfen, was noch darüber läuft.

IMAP · POP · SMTP Basic Auth

4

MFA auf alle Zugänge

Nicht nur Microsoft 365: auch VPN, Firewall-Administration, Fernwartung und Hosting-Portale.

5

Notfallkonten im Griff

Break-Glass-Konten definieren, von den Regeln ausnehmen und jede Nutzung alarmieren.

Entscheidend ist nicht, wie stark der zweite Faktor ist, sondern ob er sich phishen lässt.